



A01: BROKEN ACCESS CONTROL

Unauthorized Privilege Escalation

CRITICAL

A01:2025

CWE-266

BURP SUITE

CONFIDENTIALITY

HIGH

Full unauthorized access to the entire user database

INTEGRITY

HIGH

Modify prices, accounts and system-wide settings

AVAILABILITY

HIGH

Delete resources, ban users, or take down the application

ATTACK VECTOR

- 1 Initiate registration
Normal registration flow
- 2 Intercept in Burp Suite
Inject privilege parameter
- 3 201 Created → Admin panel
Full administrator privileges

RECOMMENDATIONS

- 1 Allow-listing – Accept only **email** och **password** from the client
- 2 Server-side role assignment – Hardcode **role: "customer"** in backend logic
- 3 DTOs – Define a strict data structure that never exposes internal model fields

```
// Intercepted request
POST [REDACTED] HTTP/1.1
Host: [REDACTED]
{
  "email": [REDACTED]
  "password": [REDACTED]
  [REDACTED] ← injected
}
HTTP/1.1 201 Created ✓
```



A01: BROKEN ACCESS CONTROL

Unauthorized Privilege Escalation

CRITICAL

A01:2025

CWE-266

BURP SUITE

CONFIDENTIALITY

HIGH

Full unauthorized access to the entire user database

INTEGRITY

HIGH

Modify prices, accounts and system-wide settings

AVAILABILITY

HIGH

Delete resources, ban users, or take down the application

ATTACK VECTOR

- 1 Initiate registration
Normal registration flow
- 2 Intercept in Burp Suite
Inject privilege parameter
- 3 201 Created → Admin panel
Full administrator privileges

RECOMMENDATIONS

- 1 Allow-listing – Accept only **email** och **password** from the client
- 2 Server-side role assignment – Hardcode **role: "customer"** in backend logic
- 3 DTOs – Define a strict data structure that never exposes internal model fields

```
// Intercepted request
POST [REDACTED] HTTP/1.1
Host: [REDACTED]
{
  "email": [REDACTED]
  "password": [REDACTED]
}
[REDACTED] - injected
HTTP/1.1 201 Created ✓
```



A01: BROKEN ACCESS CONTROL

Unauthorized Privilege Escalation

CRITICAL

A01:2025

CWE-266

BURP SUITE

CONFIDENTIALITY

HIGH

Full unauthorized access to the entire user database

INTEGRITY

HIGH

Modify prices, accounts and system-wide settings

AVAILABILITY

HIGH

Delete resources, ban users, or take down the application

```
// Intercepted request
POST [REDACTED] HTTP/1.1
Host: [REDACTED]
{
  "email": [REDACTED]
  "password": [REDACTED]
}
[REDACTED] - injected

HTTP/1.1 201 Created ✓
```

ATTACK VECTOR

- 1 Initiate registration
Normal registration flow
- 2 Intercept in Burp Suite
Inject privilege parameter
- 3 201 Created → Admin panel
Full administrator privileges

RECOMMENDATIONS

- 1 Allow-listing – Accept only email och password from the client
- 2 Server-side role assignment – Hardcode role: "customer" in backend logic
- 3 DTOs – Define a strict data structure that never exposes internal model fields



A01: BROKEN ACCESS CONTROL

Unauthorized Privilege Escalation

CRITICAL

A01:2025

CWE-266

BURP SUITE

CONFIDENTIALITY

HIGH

Full unauthorized access to the entire user database

INTEGRITY

HIGH

Modify prices, accounts and system-wide settings

AVAILABILITY

HIGH

Delete resources, ban users, or take down the application

```
// Intercepted request
POST [REDACTED] HTTP/1.1
Host: [REDACTED]
{
  "email": [REDACTED]
  "password": [REDACTED]
}
[REDACTED] - injected

HTTP/1.1 201 Created ✓
```

ATTACK VECTOR

- 1 Initiate registration
Normal registration flow
- 2 Intercept in Burp Suite
Inject privilege parameter
- 3 201 Created → Admin panel
Full administrator privileges

RECOMMENDATIONS

- 1 Allow-listing – Accept only **email** och **password** from the client
- 2 Server-side role assignment – Hardcode **role: "customer"** in backend logic
- 3 DTOs – Define a strict data structure that never exposes internal model fields

OWASP Juice Shop

Account

EN

User Registration

Email*

Password*

ⓘ Password must be 5-40 characters

11/20

longer: Password*

Show password advice

Security Question *

Your favorite movie?

ⓘ This cannot be changed later!

Answer*

lotr

Register

Already a customer?

The screenshot displays the Burp Suite interface during a network interception. At the top, the control bar shows 'Intercept on' (active), 'Forward all', and 'Drop' buttons. The main table lists intercepted requests, with the first one selected. The 'Request' tab is active, showing the raw HTTP request details. The request includes headers like 'Sec-Fetch-Mode: cors', 'Sec-Fetch-Dest: empty', 'Referer', 'Accept-Encoding: gzip, deflate, br', and 'Cookie'. The body is a JSON object with a 'securityAnswer' field set to 'lotr'. The right sidebar shows the 'Inspector' panel with sections for Request attributes, Request query parameters, Request cookies, and Request headers.

DEMO

The screenshot displays the Burp Suite interface with a Request and Response view. The Request is a POST to /api/Users/28 with various headers and a large redacted body. The Response is a 201 Created status with headers and a JSON body containing user details like username, email, and role: 'admin'. Red arrows point from the Request body to the Response body.

Request

```

1 POST /api/Users/28 HTTP/1.1
2 Host: [redacted]
3 Content-Length: 282
4 sec-ch-ua-platform: "Windows"
5 Accept-Language: sv-SE,sv;q=0.9
6 Accept: application/json, text/plain, */*
7 sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144"
8 Content-Type: application/json
9 sec-ch-ua-mobile: ?0
10 User-Agent: [redacted]
11 Origin: [redacted]
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: [redacted]
16 Accept-Encoding: gzip, deflate, br
17 Cookie: language=en; cookieconsent_status=dismiss; welcomebanner_status=dismiss
18 ; continueCode=[redacted]
19 Connection: keep-alive
20
21 {
22   [redacted]
23   [redacted]
24   [redacted]
25   [redacted]
26   [redacted]
27   [redacted]
28   [redacted]
29   [redacted]
30   [redacted]
31   [redacted]
32   [redacted]
33   [redacted]
34   [redacted]
35   [redacted]
36   [redacted]
37   [redacted]
38   [redacted]
39   [redacted]
40   [redacted]
41   [redacted]
42   [redacted]
43   [redacted]
44   [redacted]
45   [redacted]
46   [redacted]
47   [redacted]
48   [redacted]
49   [redacted]
50   [redacted]
51   [redacted]
52   [redacted]
53   [redacted]
54   [redacted]
55   [redacted]
56   [redacted]
57   [redacted]
58   [redacted]
59   [redacted]
60   [redacted]
61   [redacted]
62   [redacted]
63   [redacted]
64   [redacted]
65   [redacted]
66   [redacted]
67   [redacted]
68   [redacted]
69   [redacted]
70   [redacted]
71   [redacted]
72   [redacted]
73   [redacted]
74   [redacted]
75   [redacted]
76   [redacted]
77   [redacted]
78   [redacted]
79   [redacted]
80   [redacted]
81   [redacted]
82   [redacted]
83   [redacted]
84   [redacted]
85   [redacted]
86   [redacted]
87   [redacted]
88   [redacted]
89   [redacted]
90   [redacted]
91   [redacted]
92   [redacted]
93   [redacted]
94   [redacted]
95   [redacted]
96   [redacted]
97   [redacted]
98   [redacted]
99   [redacted]
100  [redacted]
101  [redacted]
102  [redacted]
103  [redacted]
104  [redacted]
105  [redacted]
106  [redacted]
107  [redacted]
108  [redacted]
109  [redacted]
110  [redacted]
111  [redacted]
112  [redacted]
113  [redacted]
114  [redacted]
115  [redacted]
116  [redacted]
117  [redacted]
118  [redacted]
119  [redacted]
120  [redacted]
121  [redacted]
122  [redacted]
123  [redacted]
124  [redacted]
125  [redacted]
126  [redacted]
127  [redacted]
128  [redacted]
129  [redacted]
130  [redacted]
131  [redacted]
132  [redacted]
133  [redacted]
134  [redacted]
135  [redacted]
136  [redacted]
137  [redacted]
138  [redacted]
139  [redacted]
140  [redacted]
141  [redacted]
142  [redacted]
143  [redacted]
144  [redacted]
145  [redacted]
146  [redacted]
147  [redacted]
148  [redacted]
149  [redacted]
150  [redacted]
151  [redacted]
152  [redacted]
153  [redacted]
154  [redacted]
155  [redacted]
156  [redacted]
157  [redacted]
158  [redacted]
159  [redacted]
160  [redacted]
161  [redacted]
162  [redacted]
163  [redacted]
164  [redacted]
165  [redacted]
166  [redacted]
167  [redacted]
168  [redacted]
169  [redacted]
170  [redacted]
171  [redacted]
172  [redacted]
173  [redacted]
174  [redacted]
175  [redacted]
176  [redacted]
177  [redacted]
178  [redacted]
179  [redacted]
180  [redacted]
181  [redacted]
182  [redacted]
183  [redacted]
184  [redacted]
185  [redacted]
186  [redacted]
187  [redacted]
188  [redacted]
189  [redacted]
190  [redacted]
191  [redacted]
192  [redacted]
193  [redacted]
194  [redacted]
195  [redacted]
196  [redacted]
197  [redacted]
198  [redacted]
199  [redacted]
200  [redacted]
201  [redacted]
202  [redacted]
203  [redacted]
204  [redacted]
205  [redacted]
206  [redacted]
207  [redacted]
208  [redacted]
209  [redacted]
210  [redacted]
211  [redacted]
212  [redacted]
213  [redacted]
214  [redacted]
215  [redacted]
216  [redacted]
217  [redacted]
218  [redacted]
219  [redacted]
220  [redacted]
221  [redacted]
222  [redacted]
223  [redacted]
224  [redacted]
225  [redacted]
226  [redacted]
227  [redacted]
228  [redacted]
229  [redacted]
230  [redacted]
231  [redacted]
232  [redacted]
233  [redacted]
234  [redacted]
235  [redacted]
236  [redacted]
237  [redacted]
238  [redacted]
239  [redacted]
240  [redacted]
241  [redacted]
242  [redacted]
243  [redacted]
244  [redacted]
245  [redacted]
246  [redacted]
247  [redacted]
248  [redacted]
249  [redacted]
250  [redacted]
251  [redacted]
252  [redacted]
253  [redacted]
254  [redacted]
255  [redacted]
256  [redacted]
257  [redacted]
258  [redacted]
259  [redacted]
260  [redacted]
261  [redacted]
262  [redacted]
263  [redacted]
264  [redacted]
265  [redacted]
266  [redacted]
267  [redacted]
268  [redacted]
269  [redacted]
270  [redacted]
271  [redacted]
272  [redacted]
273  [redacted]
274  [redacted]
275  [redacted]
276  [redacted]
277  [redacted]
278  [redacted]
279  [redacted]
280  [redacted]
281  [redacted]
282  [redacted]
283  [redacted]
284  [redacted]
285  [redacted]
286  [redacted]
287  [redacted]
288  [redacted]
289  [redacted]
290  [redacted]
291  [redacted]
292  [redacted]
293  [redacted]
294  [redacted]
295  [redacted]
296  [redacted]
297  [redacted]
298  [redacted]
299  [redacted]
300  [redacted]
301  [redacted]
302  [redacted]
303  [redacted]
304  [redacted]
305  [redacted]
306  [redacted]
307  [redacted]
308  [redacted]
309  [redacted]
310  [redacted]
311  [redacted]
312  [redacted]
313  [redacted]
314  [redacted]
315  [redacted]
316  [redacted]
317  [redacted]
318  [redacted]
319  [redacted]
320  [redacted]
321  [redacted]
322  [redacted]
323  [redacted]
324  [redacted]
325  [redacted]
326  [redacted]
327  [redacted]
328  [redacted]
329  [redacted]
330  [redacted]
331  [redacted]
332  [redacted]
333  [redacted]
334  [redacted]
335  [redacted]
336  [redacted]
337  [redacted]
338  [redacted]
339  [redacted]
340  [redacted]
341  [redacted]
342  [redacted]
343  [redacted]
344  [redacted]
345  [redacted]
346  [redacted]
347  [redacted]
348  [redacted]
349  [redacted]
350  [redacted]
351  [redacted]
352  [redacted]
353  [redacted]
354  [redacted]
355  [redacted]
356  [redacted]
357  [redacted]
358  [redacted]
359  [redacted]
360  [redacted]
361  [redacted]
362  [redacted]
363  [redacted]
364  [redacted]
365  [redacted]
366  [redacted]
367  [redacted]
368  [redacted]
369  [redacted]
370  [redacted]
371  [redacted]
372  [redacted]
373  [redacted]
374  [redacted]
375  [redacted]
376  [redacted]
377  [redacted]
378  [redacted]
379  [redacted]
380  [redacted]
381  [redacted]
382  [redacted]
383  [redacted]
384  [redacted]
385  [redacted]
386  [redacted]
387  [redacted]
388  [redacted]
389  [redacted]
390  [redacted]
391  [redacted]
392  [redacted]
393  [redacted]
394  [redacted]
395  [redacted]
396  [redacted]
397  [redacted]
398  [redacted]
399  [redacted]
400  [redacted]
401  [redacted]
402  [redacted]
403  [redacted]
404  [redacted]
405  [redacted]
406  [redacted]
407  [redacted]
408  [redacted]
409  [redacted]
410  [redacted]
411  [redacted]
412  [redacted]
413  [redacted]
414  [redacted]
415  [redacted]
416  [redacted]
417  [redacted]
418  [redacted]
419  [redacted]
420  [redacted]
421  [redacted]
422  [redacted]
423  [redacted]
424  [redacted]
425  [redacted]
426  [redacted]
427  [redacted]
428  [redacted]
429  [redacted]
430  [redacted]
431  [redacted]
432  [redacted]
433  [redacted]
434  [redacted]
435  [redacted]
436  [redacted]
437  [redacted]
438  [redacted]
439  [redacted]
440  [
```



A01: BROKEN ACCESS CONTROL

Unauthorized Privilege Escalation

CRITICAL

A01:2025

CWE-266

BURP SUITE

CONFIDENTIALITY

HIGH

Full unauthorized access to the entire user database

INTEGRITY

HIGH

Modify prices, accounts and system-wide settings

AVAILABILITY

HIGH

Delete resources, ban users, or take down the application

ATTACK VECTOR

- 1 Initiate registration
Normal registration flow
- 2 Intercept in Burp Suite
Inject privilege parameter
- 3 201 Created → Admin panel
Full administrator privileges

RECOMMENDATIONS

- 1 Allow-listing – Accept only **email** och **password** from the client
- 2 Server-side role assignment – Hardcode **role: "customer"** in backend logic
- 3 DTOs – Define a strict data structure that never exposes internal model fields

```
// Intercepted request
POST [REDACTED] HTTP/1.1
Host: [REDACTED]
{
  "email": [REDACTED]
  "password": [REDACTED]
  [REDACTED] ← injected
}
HTTP/1.1 201 Created ✓
```




A01: BROKEN ACCESS CONTROL

Unauthorized Privilege Escalation

CRITICAL

A01:2025

CWE-266

BURP SUITE

CONFIDENTIALITY

HIGH

Full unauthorized access to the entire user database

INTEGRITY

HIGH

Modify prices, accounts and system-wide settings

AVAILABILITY

HIGH

Delete resources, ban users, or take down the application

ATTACK VECTOR

- 1 Initiate registration
Normal registration flow
- 2 Intercept in Burp Suite
Inject privilege parameter
- 3 201 Created → Admin panel
Full administrator privileges

RECOMMENDATIONS

- 1 Allow-listing – Accept only **email** och **password** from the client
- 2 Server-side role assignment – Hardcode **role: "customer"** in backend logic
- 3 DTOs – Define a strict data structure that never exposes internal model fields

```
// Intercepted request
POST [REDACTED] HTTP/1.1
Host: [REDACTED]
{
  "email": [REDACTED]
  "password": [REDACTED]
}
[REDACTED] - injected
HTTP/1.1 201 Created ✓
```



Conclusion and Lessons Learned

Project Outcome

- **Comprehensive Audit:** Successfully identified, verified and documented >6 vulnerabilities within OWASP Juice Shop environment, covering both logic- and technical flaws.
- **Security Impact:** The findings spanned a wide range - from information leakage to critical admin takeovers. This highlights significant exposure across the whole platform, covering all CIA pillars.
- **Goal Achievement:** All audit objectives were met, with findings categorized across **5 distinct OWASP Top 10:2025 categories**.

Technical Reflection

- **Pivoting:** My initial focus was a **JWT Forgery** attack. Upon discovering that this specific flaw was patched in **v19.1.1**, I successfully pivoted to exploit the **Broken Access Control** logic flaw.
- **Key Lesson:** Security is a moving target. This pivot demonstrated that even when a known signature-vulnerability (JWT) is fixed, underlying logic flaws in the API often remain, providing alternative paths for an attacker.

```
POST /api/admin/  
"role": "admin"  
201 Created
```



Broken Access Control

CWE-266

A01:2025



Broken Access Control
Privilege Escalation
A01:2025



Conclusion and Lessons Learned

Project Outcome

- **Comprehensive Audit:** Successfully identified, verified and documented >6 vulnerabilities within OWASP Juice Shop environment, covering both logic- and technical flaws.
- **Security Impact:** The findings spanned a wide range - from information leakage to critical admin takeovers. This highlights significant exposure across the whole platform, covering all CIA pillars.
- **Goal Achievement:** All audit objectives were met, with findings categorized across **5 distinct OWASP Top 10:2025 categories**.

Technical Reflection

- **Pivoting:** My initial focus was a **JWT Forgery** attack. Upon discovering that this specific flaw was patched in **v19.1.1**, I successfully pivoted to exploit the **Broken Access Control** logic flaw.
- **Key Lesson:** Security is a moving target. This pivot demonstrated that even when a known signature-vulnerability (JWT) is fixed, underlying logic flaws in the API often remain, providing alternative paths for an attacker.

Any questions?

Yes

No

